

Stack 07b — ERC-7730 formatters (Phases A–E): audit record, 2026-09-25

Canonical audit identity and status

This report follows the main firmware worktree's `docs/release/MASTER-AUDIT-TEMPLATE.md` at SHA256 `743843a17139a7394325a961b9a38666c8e8af7a0005e0ff52eb94559ec8dbb7`. The code-bearing review is [PR #863](#), targeting `release/715-stack-07-erc7730-core` at immutable base `8c654bcd8e1c8936a86aaa625a4ab78900a250e9`. The last fully validated code, test and dependency head before this report update is `5e00cc6d8d62c190d6f60793117fc421652d3ff7`; repair code head `2cce087c1160a818109141a805a61223ed4748e5`. Exact-head [CI 36197508235](#) passed all 16 required jobs. The final containing report commit belongs in the PR description, since this source cannot name its own commit.

Checkpoint	Status through the second-review local repair	Limit
Implementation	Complete for the selected 7.15 Phase A–E subset	7.16 DELEGATECALL and hard-refusal policy remain outside this block.
Targeted verification	Prior head: 202 focused firmware tests, 38 runtime and 21 inherited 7a wire tests. Local repair: 59 focused firmware tests and the complete 656/135 full/BTC firmware suites pass.	The wire and hosted evidence still describes the earlier code head.
Integration verification	Prior head: exact-head full/BTC hosted CI, ARM and report gates. Local repair: both ARM variants link and pass SRAM gates.	New-head hosted CI remains pending; publication is separate.
Adversarial contract verification	Initial and four-round re-audit findings repaired, with regression controls; two second-review regressions have local positive and negative controls.	The re-audit's two-dry-round stop rule was not reached.
External review delivery	First review 5323189342 found four issues and their threads are resolved. Second review 5323944293 on 5e00cc6d8 found two further issues.	Current-head review remains pending.
Finding disposition	Both second-review issues are repaired in 2cce087c1 with independently failing negative controls.	Pushed-source replies, thread resolution and exact-head CI remain pending.
Release acceptance	Pending	Physical-device checks, assembled release and promotion are separate.

The firmware pins `python-keepkey 4f114707f4401002646febc12c370b766ebd059d` (upstream PR #228) and `device-protocol 5fec9e6906a340be5eb3d795ec746769065b2db8` (upstream PR #123). Both pins were clean in the local worktree; the parent PR's exact-head CI checked the same pointers.

Scope and identity

Block 7b is [PR #863](#), stacked on block 7a ([PR #837](#), head `8c654bcd8`). Block 7 was split in two under the owner's 20,000-line limit. 7a is [PR #837](#) plus Phase 0 (one capability table, enforced at preload). 7b is Phases A–E of `docs/security/HANDOFF-ERC7730-715-FORMATTERS.md` and `docs/security/HANDOFF-ERC7730-PHASE-E.md`.

Item	Value
Firmware base (7a head)	8c654bcd8
Firmware 7b commits	e5efe90de Phase A, 6bf5c72ba B, f4f3f6250 C, 4d124d1b6 up-front validation, 4978ae7df D, e942f18b3/6cabb1585 Phase E requirements and owner rule, 234377914 E1, 8ad196ca6 E2, 2e11b98d0/fdd0c3e44 first audit remediation, cab397689 report integration, da2fe16dd/820d0da53/93394038c/d7f7c76d6 re-audit fixes, 5e00cc6d8 first Copilot repair, 2cce087c1 second Copilot repair
Size	firmware +3.5k/−0.4k lines over 31 files; python-keepkey +1.5k lines over 6 files. Well under the 20k limit.
python-keepkey	keepkey/python-keepkey branch release/715-stack07b-formatters (PR #228, onto 7a's #227), also on the BitHighlander fork
device-protocol	unchanged from 7a: 5fec9e69, the head of device-protocol PR #123 into up/release-protocol (DebugLink confirm_title/confirm_body)

The final head and its hosted CI run are recorded in the PR description, because this file cannot name its own commit.

What 7b makes the device execute

One capability table (`erc7730_capabilities.{h,c}`) is shared by the preload verifier, the runtime and python-keepkey's compiler mirror (`DEVICE_CAPABILITIES`, `device_refusal`). Anything outside it is refused at preload, before any screen.

Phase	Adds	Official registry formats the device signs (of 1,450)
0 (7a)	raw formatter, index paths	92
A	tokenAmount, addressName, @.from/@.to, signed constants (raw fields only, after the re-audit)	812
B	interpolated intent as numbered parts	954
C	amount, nftName, date, duration, unit, enum, @.value	1,138
D	groups, one array iterated at a time, condition "optional" (always shown)	1,294
E1	embedded calls under a blind-sign warning (7.15 rule)	1,326
E2	inner calls clear-signed with their own definition, one level deep	1,326 (runtime only)

The count is asserted in lockstep by `test_erc7730_compiler.py` (`REGISTRY_SIGNABLE`) against the firmware's own verifier (`tools/erc7730-validate`). Owner rule (2026-09-25): in 7.15, what cannot be clear-signed may be shown under a "Blind signature" warning, behind AdvancedMode. 7.16 makes AdvancedMode a hard gate and rejects it.

First adversarial audit and remediation

A 102-agent audit of the 7b diff confirmed 42 findings, clustered as D1–D19. None was P1. The dispositions are in `docs/security/HANDOFF-ERC7730-PHASE-E.md` §9c. In short:

- **Mid-review failures now refused at preload or handled:**
 - numeric constants (D1);
 - an embedded call as an intent part (D2);
 - signer text over 64 bytes or unit decimals over 77 (D3);
 - a literal callee (D9);
 - control characters (escaped, D8);
 - raw values over 128 bytes (shown blind with their length, D8);

- a refused inner definition (falls back to blind, D17);
- an inner definition showing `@.value` with no `amountPath` (blind).
- **Wrong source for a fact:** a stale Wanchain transaction type (D4); a signer alias overriding the firmware token table (D5).
- **Presentation:** distinct "Intent text/value i of n" and "Signer field i of N" titles (D6/D14); numbered confirmations split between lines (D7); unit bases and threshold messages marked as the signer's, and units always show the raw integer (D16).
- **Documented, fail closed:** parallel arrays pair by index (D10); fixed indices into short dynamic arrays (D18); the inner validation pass after the outer screens; N leaf reviews for N typed-data fields.
- **Open for 7.16:** DELEGATECALL is not tied to the inner review.

Each fix has a named wire or unit test. Reverting each check on its own turns its test red: 23 firmware controls and 3 python-keepkey controls, including the re-audit's below. The callee/chain binding is enforced twice (header screen and `erc7730_workflow_fetch_complete`), so its control removes both.

Re-audit of the remediation

A second adversarial workflow audited the remediation diff (`8ad196ca6..fdd0c3e44` plus python-keepkey `f8c8d31..75585fe`) at a frozen worktree. It ran seven finder lenses per round: lockstep, state machine, text and titles, fact sources, capture overflow, tests and controls, and docs claims. Three independent refuters then voted on every fresh finding, and a completeness critic closed the run. It used 170 agents over four rounds, with no agent errors.

Round	Reported	Confirmed (≥ 2 of 3 votes)
1	30	17
2	7	1
3	3	1
4	7	2

Several lenses reported the same defect, so the 21 confirmations cover 14 distinct defects. None is P1. Each is fixed in `da2fe16dd`, `820d0da53`, `93394038c` or `d7f7c76d6`:

S ev	Defect	Fix
P2	An enum over a one-byte constant passed preload and failed mid-review (D1 residual)	Preload refuses it. After round 4, every formatter but raw refuses a constant value.
P2	A signer constant could appear under the device-owned "Intent value" title	Preload refuses a constant as an intent value. The registry uses none.
P3	A Wanchain <code>tx_type</code> took the certified path, and its value was named ETH	The certified path refuses <code>tx_type</code> before any screen
P3	"Inner intent value i of n" plus the pager suffix overflowed the OLED title	Titles are now "Inner text/value i of n"
P3	The mirror had no limit on the bindings table	Added: 64
P3	Enum labels were signer text with no mark	Marked "label set by signer"
P3	Signer marks came after the value, so the pager could move them to a later page	The mark now comes first
P3	A typed-data raw value over 128 bytes showed a false "Blind signature"	It now reads "Shown above in full: N bytes"; the walk has already shown the value
P3	The D7 claim was false on the OLED: the board pager still wraps within a confirmation	Docs and report corrected
P3	Stale doc title; "N+1" should be N typed-data leaf reviews; DELEGATECALL was listed as fail-closed	Docs corrected
P3	Test gaps: the "depth two" test had no depth-2 call; <code>_certified</code> did not prove the certified path ran; the Wanchain test leaked state; the D3 limits were untested	New depth-2 test; definition-request check; state restored; unit tests

The completeness critic resolved 14 gaps. One was a defect: a constant embedded value (role 17) got past the no-amountPath refusal. Preload now refuses constants for roles 15, 17 and 18.

It left one question for the owner: may formatters show numeric constants at all? Refusing them removes no official registry format (measured with the mirror, with a positive control), so they are refused. It also noted two undocumented behaviour changes, now recorded in PHASE-E §9c:

- D8's escaping reaches the ordinary streamed EIP-712 review;
- the callee may come from @.from.

Refuted but acted on anyway:

- Three lockstep gaps that predate this block, each failing closed:
 - fixed arrays over 64 elements;
 - non-printable program strings;
 - non-minimal signed enum keys, which the compiler emitted for -128 and made the device refuse.
The host side now matches the device.
- Four test gaps:
 - a refusal on a later chunk of a multi-chunk inner definition;
 - a second embedded call after a refused one;
 - declining each kind of certified screen;
 - both halves of a parallel-array pair.

Convergence. The loop's stop rule (two dry rounds) was not met within its four-round cap: round 4 still confirmed two P3 findings. Both are fixed, but a fifth round has not been run against the final head.

Evidence for the release report

- The Phase 0–E runtime tests (38, including the re-audit's) moved to python-keepkey tests/test_msg_ethereum_erc7730_runtime.py, because only python-keepkey tests get OLED captures in the release PDF.
 - They form report section **EX** (7.15.0+), rows EX1–EX38, 29 of them with declared OLED screens.
 - The module is must-run from 7.15.0 on the full product. On bitcoin-only it skips by design.
 - Every signing test first signs the same transaction on the ordinary path. It requires an identical signature and that the device asked for the definition.
- Captures cover the screens the definition adds. The ordinary review that follows is not captured: it is unchanged, which the identical signature proves.
- Hosted CI on cab397689 rendered EX (34/34 at that head) with 183 OLED frames, none blank. They were checked in the downloaded artifacts and in the PDF itself. The report's screenshot audit found no EX test short of its declared frames. Four flows (interpolated intent, blind embedded call, inner clear-sign, refused inner definition) are rendered in full sequence.
- scripts/emulator/test_stack07_regressions.py keeps the 7a contracts that CONTRACT_JUNIT requires (21 tests) and imports its harness from the python-keepkey module.
- The old report section ER ("v2 conformance", gated at 7.19.0) is unchanged. Its prose describes the compiler and program format, not what 7.15 executes. It is not active for 7.15.

Verification (local, CI base image `kk837-dev`)

Check	Result
Firmware unit (Erc7730*, EIP712*, Ethereum*)	202 pass; bitcoin-only builds and excludes them
Wire, full product	38 runtime + 21 stack07 = 59 pass

Check	Result
Wire, bitcoin-only	CoinTable passes; every EVM case skips by design
python-keepkey host, KK_REQUIRE_ERC7730_EVIDENCE=1 with the pinned registry 9f37816a and the firmware validator, plus the report validator tests	35 pass; 1,326 signable
ARM MinSizeRel + tools/check_sram_budget.py	full reserve 17,840 B (7a: 18,336 B; -496 B over 7b), bitcoin-only 39,136 B; largest frame 7,664 B; pass. Deepest ERC-7730 frame fsm_msgEthereumClearSignDefinitionChunk 2,344 B. ROM text 617,168 B.
cppcheck 2.13 (Ubuntu 24.04, CI flags, whole tree)	zero findings
clang-format 20	clean on every CI-checked file
Hosted CI	fdd0c3e44 (run 36141175316) and cab397689 (run 36148577063, including generate-test-report and release-evidence-gate) green; later heads in the PR

SRAM: 7b spends 496 B of reserve over nine commits; no single commit exceeds the 256 B single-change review rule.

First Copilot review

The first Copilot review of [ed6c8e3a7](#) reported four findings. One found that a scalar formatter value could be repeated inside an iteration; the firmware verifier and python-keepkey mirror now require the value to walk the active array, with a positive and negative lockstep test. Parallel auxiliary arrays still pair by index as documented in D10. The other three findings were stale phase counts, E1/E2 status and the EX test count; the handoffs now match the final implementation and 38-test inventory. The focused firmware catalog suite passed (46 tests), and the compiler suite passed with the pinned registry and rebuilt device validator (16 tests).

Second Copilot review and repair

Review [5323944293](#)

assessed exact head [5e00cc6d8](#) and returned **Changes recommended** with two inline findings. Both are security-relevant and remain open on the PR until the repaired source is pushed with individual replies:

Finding	Origin, observer and phase	Local repair and falsification
Path classes shared storage with group/iteration frames	A signed definition supplies paths and display instructions. The preload verifier uses <code>signature[]</code> for both path-class bytes and active display frames. The current parser finishes formatter type checks before it opens display frames, so the review's proposed later type-check failure was not reproduced; the alias nevertheless made those facts overlap.	A separate <code>display_frames[]</code> keeps path classes intact. <code>DisplayFramesPreservePathClasses</code> passes on the repair and fails when the old frame pointer is restored. The test feeds an actual group instruction after path validation.
NUL can truncate signer text in a C-string display	A signed program string is copied by the replay reader into a NUL-terminated buffer before the OLED caller formats it. The catalog already refuses <code>U+0000</code> in its UTF-8 validator, but the independent reader accepted it.	The reader now refuses any embedded NUL, including in an unselected string. <code>RejectsEmbeddedNulBeforeDisplay</code> passes across one-byte and whole-section chunks and fails four assertions when the new reader guard is removed. The catalog's separate one-byte and multi-byte NUL refusal checks pass.

The repaired code is committed at [2cce087c1](#). The normal pinned full-product image builds. Focused catalog, reader and workflow tests pass 59/59; the complete full native firmware suite passes 656/656, board 19/19 and crypto 18/18. Bitcoin-only builds and passes its complete 135/135 firmware suite. Both MinSizeRel ARM variants link; the SRAM

budget gate passes with 17,800 B full and 39,136 B Bitcoin-only reserve, largest frame 7,664 B. These are local exact-code-head results, not a hosted exact-head CI claim. The local device build needed only a correction to the generated protoc command's plugin name; no firmware source or protocol definition was changed for that workaround.

Not verified

- **Physical device.** No 7b build has been flashed or run on hardware, and there are no OLED photographs from a device. The emulator frames above are the only display evidence.
- **Copilot convergence.** The second review found two issues; committed repairs have not yet been pushed or reviewed on their final head.
- Pre-existing duplicate nanopb options in `messages-osmosis.options` and `messages-solana.options` (from the 00b stack, 4c56e19e3), flagged by `scripts/preflight.sh`, are outside 7b.
- **Pre-push gate.** The canonical `scripts/preflight.sh` from `audit/715-00b-review-sop` was run after the repair. It failed on those inherited duplicate options and on `scripts/test_generate_test_report.py`, which is absent from this 7b branch. The local `cppcheck` invocation in that script also references a missing `.cppcheck-build` path; an updated local copy with `/tmp/cppcheck-build` completed its `cppcheck` step but still failed the two inherited checks. The script's fail-closed result is preserved; it is not called a passing preflight.
- **Historical-finding granularity.** The Phase E handoff clusters the first audit's 42 findings under D1–D19 but does not retain a row for each raw finding. The re-audit likewise records its 14 distinct defects in prose and tests. Those source records support the grouped dispositions above, but they cannot satisfy a per-finding closure matrix for every original report without the raw manifests. The two Copilot findings above include their direct source, observer, entry path, positive and negative checks; broader historical matrix completion remains an evidence gap.
- Presentation limits: the board pager wraps by pixel width, so a checksummed address can continue on the next OLED page of the same confirmation. An array element whose value needs numbered parts and also pages can exceed the title width.

Immutable historical commit inventory

Each row comes from `git show --format= --numstat COMMIT_SHA`. Counts include code, tests, documentation and submodule pointer lines where present. The rows overlap in changed lines and must not be summed as the net PR diff. The adjacent code-and-report predecessor is

8c654bcd8e1c8936a86aaa625a4ab78900a250e9..2cce087c1160a818109141a805a61223ed4748e5: 33 paths, 3,869 additions and 414 deletions at that snapshot.

Commit	Paths	Added	Deleted	Prior-to-new behavior and evidence
e5efe90de	18	1291	104	Adds device decoding and display for Phase A; formatter and wire tests exercise signed-value rendering.
6bf5c72ba	13	174	18	Adds numbered intent parts; wire/OLED tests exercise text and value order.
f4f3f6250	14	916	205	Adds Phase C formatter families; capability and value tests cover bounds and raw fallback.
4d124d1b6	4	70	19	Moves calldata validity checks before review; negative preload tests cover refusal.
4978ae7df	12	423	45	Adds groups, iteration and optional display; iteration and pairing tests cover execution.
e942f18b3	1	149	0	Records Phase E requirements; documentation only.
6cabb1585	1	5	0	Records owner blind-sign rule; documentation only.

Commit	Paths	Added	Deleted	Prior-to-new behavior and evidence
234377914	14	284	9	Adds E1 blind warning for embedded calls; wire tests cover warning and continuation.
8ad196ca6	8	556	24	Adds one-level authenticated inner review; wire tests cover definition binding and outer signature.
2e11b98d0	21	804	246	Repairs initial audit findings; regressions and negative controls are listed above.
fdd0c3e44	2	27	6	Records finding dispositions and limits; documentation only.
cab397689	3	10	890	Moves runtime tests into the release report and pinned dependency; EX report rows prove registration.
da2fe16dd	7	111	16	Repairs re-audit findings in source and tests; capability controls cover the changed rules.
820d0da53	4	7	5	Marks enum labels as signer text; display tests cover wording.
93394038c	2	5	2	Corrects fail-closed versus signable claims; documentation only.
d7f7c76d6	9	60	47	Repairs later re-audit findings; targeted regressions cover the changes.
ed6c8e3a7	1	131	0	Adds the audit record; documentation only.
5e00cc6d8	6	26	15	Repairs first Copilot findings in verifier, mirror, tests and handoffs.
2cce087c1	5	59	2	Separates display-frame storage and rejects embedded NUL in replayed strings; native regressions and negative controls pass.

The final inventory must be regenerated after the report source and PDF are committed. The containing final PR SHA is recorded in the PR description.

Adjacent path inventory at the repaired code head

Reproduce with `git diff --numstat --no-renames`

8c654bcd8e1c8936a86aaa625a4ab78900a250e9...2cce087c1160a818109141a805a61223ed4748e5.

This immutable snapshot contains 33 paths, 3,869 additions and 414 deletions.

The final report/PDF commit will add its documentation delta and PDF path; its exact final inventory belongs in the PR description.

Path	Added	Deleted	Role
deps/python-keepkey	1	1	dependency pin
docs/release/audit-units/715-07b-formatters-audit-20260925.md	135	0	handoff/report
docs/security/HANDOFF-ERC7730-715-FORMATTERS.md	86	2	handoff/report
docs/security/HANDOFF-ERC7730-PHASE-E.md	209	0	handoff/report
include/keepkey/firmware/eip712_stream.h	3	0	API/contract
include/keepkey/firmware/erc7730_abi_stream.h	9	0	API/contract
include/keepkey/firmware/erc7730_capabilities.h	80	10	API/contract
include/keepkey/firmware/erc7730_catalog.h	19	0	API/contract
include/keepkey/firmware/erc7730_field.h	68	0	API/contract
include/keepkey/firmware/erc7730_format.h	5	5	API/contract
include/keepkey/firmware/erc7730_program.h	4	0	API/contract

Path	Added	Deleted	Role
include/keepkey/firmware/erc7730_workflow.h	123	0	API/contract
include/keepkey/firmware/ethereum.h	4	0	API/contract
lib/firmware/CMakeLists.txt	1	0	build registration
lib/firmware/eip712_stream.c	10	0	runtime
lib/firmware/erc7730_abi_stream.c	34	4	runtime
lib/firmware/erc7730_capabilities.c	184	11	runtime
lib/firmware/erc7730_catalog.c	158	7	runtime
lib/firmware/erc7730_field.c	287	0	runtime
lib/firmware/erc7730_format.c	1	5	runtime
lib/firmware/erc7730_program.c	12	0	runtime
lib/firmware/erc7730_workflow.c	377	16	runtime
lib/firmware/ethereum.c	12	0	runtime
lib/firmware/fsm.c	2	1	runtime
lib/firmware/fsm_msg_ethereum.h	1052	95	runtime
scripts/emulator/test_stack07_regressions.py	6	191	wire regression
unittests/firmware/CMakeLists.txt	1	0	native regression
unittests/firmware/erc7730_abi_stream.cpp	10	2	native regression
unittests/firmware/erc7730_catalog.cpp	639	49	native regression
unittests/firmware/erc7730_field.cpp	293	0	native regression
unittests/firmware/erc7730_format.cpp	14	10	native regression
unittests/firmware/erc7730_program.cpp	21	0	native regression
unittests/firmware/erc7730_workflow.cpp	9	5	native regression

Final artifact inventory

The report source is this Markdown file. Its rendered companion is docs/release/audit-units/715-07b-formatters-audit-20260925.pdf (A4, eight pages); the PDF was opened and its extracted text checked against the source. Both artifacts must be present in the final adjacent PR diff. That final diff has 34 paths, including the PDF binary. The Markdown source contributes 280 added lines and zero deletions; all other text paths at the repaired code head contribute 3,734 additions and 414 deletions. Thus the final adjacent text diff has 4,014 additions and 414 deletions. Reproduce after the containing report commit with `git diff --numstat --no-renames 8c654bcd8e1c8936a86aaa625a4ab78900a250e9..FINAL_HEAD` and substitute the final commit SHA from PR #863 for FINAL_HEAD. The PDF is binary and its numstat entry is - -.